PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Guide ANSSI sur le vote par internet

03-1380 ANSSI - Vote par internet pour les élections non politiques — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le guide s'applique aux élections non politiques et aux primaires des partis, mais exclut les élections politiques.
2. La sécurité du secret du scrutin n'est garantie qu'à court terme, environ 5 ans, face à la menace quantique.
3. Les recommandations de sécurité sont cumulatives, le niveau 3 incluant les exigences des niveaux 1 et 2.

Cadre du guide ANSSI-PA-118

Notion	À retenir
Objet et public	Guide **ANSSI-PA-118** (v1.0, **24/04/2026**) approfondissant la délibération CNIL **n° 2026-045** du **19/03/2026**. Concerne **élections non politiques** et **scrutin secret** (inclut primaires).
Principes fondamentaux	Garantit **secret**, **caractère personnel/libre**, **sincérité**, **intégrité**, **accès**, **surveillance** et **contrôle juge**. Risque : relier **identité** et **suffrage** via l'authentification et le traitement numérisés.
Enjeux particuliers	Exige **vérifiabilité** (individuelle/universelle), **transparence** (principe de **Kerckhoffs**), **surveillance** (journalisation), protection contre la **coercition** (**receipt-freeness** : l'électeur ne peut prouver son vote à un tiers, ce qui n'exclut pas un récépissé). Secret protégé à court terme (**~5 ans**) face au **quantique**.

Les trois niveaux de scrutin de la CNIL

Notion	À retenir
Le principe des niveaux	L'organisateur classe le scrutin en **niveau 1, 2 ou 3**. Les recommandations **R1 à R74** sont **cumulatives** (le niveau 3 inclut les niveaux 1 et 2).
Le niveau 1	Risques faibles (ex: **associations locales**). Système, prestataire et organisateur **supposés de confiance**. **11 objectifs** (**1-01 à 1-11**) sans exigence de transparence ou de preuve.
Le niveau 2	Risques modérés (ex: **représentants du personnel**). Prestataire et organisateur **peuvent porter atteinte** à la sécurité. **9 objectifs** (**2-01 à 2-09**) avec surveillance effective et durcissement.
Le niveau 3	Risques significatifs (ex: **ordres professionnels**). Attaque possible par **acteurs internes ou externes** avec **ressources importantes**. **5 objectifs** (**3-01 à 3-05**) et recommandations **R70 à R74** selon l'analyse de risque.

Recommandations de sécurité du vote par internet

Notion	À retenir
Solution, vote, récépissé	Vote **indivisible** (**validation**, **enregistrement**, **émargement**, **délivrance**). Récépissé par courriel **sans information** liée au bulletin. Mécanismes cryptographiques conformes **ANSSI**.
Authentification	Niveau 1 : solution **externe** ou **secret dédié**. Niveaux 2 et 3 : **deux secrets** via **deux canaux différents**. Le recouvrement d'un secret ne doit pas abaisser la sécurité.
Confidentialité, intégrité	Suffrage chiffré par le **client** (pas le serveur), chiffrement **asymétrique probabiliste et non malléable** ; **ElGamal**, malléable seul, n'est admis qu'avec des **preuves complémentaires** (pastillage). **TLS** (flux internes : authentification mutuelle). **PDMA nulle** : aucun bulletin perdu.
Étanchéité, dépouillement	Étanchéité par **accumulation** ou **mélange cryptographique**. Clé privée fragmentée par **partage de secret à seuil**. **Pastillage** pour détecter les déplacements.
Surveillance, disponibilité	Journalisation (fonctionnement, secret, intégrité, sincérité). Niveau 2 : **redondé** et **protégé DoS**. Niveau 3 : **répliqué** dans un second centre de données ou zone cloud distant.
Vérifiabilité, transparence	Niveau 2 : **preuve de vote** sans identité/horodatage et protocole **public**. Niveau 3 : **mélange/accumulation vérifiable** et déchiffrement par **preuves à divulgation nulle de connaissance**.
Recommandations complémentaires	R70 : clé indépendante ; R71 : clé privée sur **serveur hors ligne** ; R72 : génération **distribuée** ; R73 : déchiffrement vérifiable distribué ; R74 : **partage de secret à seuil vérifiable**.

Risques non couverts et conséquences

Notion	À retenir
Les cinq limites	Copie de **clé privée** (collusion), **achat/coercition** de vote, **intention** non vérifiable (navigateur/OS compromis), **ordinateur quantique** (*everlasting privacy*), **fausses informations**.
La conséquence	**Même au niveau 3**, le guide ne protège pas contre un État ou complicités. Si risques non gérables, abandon du vote par Internet pour le **vote à l'urne**.

Pièges et confusions

- ⚠ Confondre le bulletin numérique avec le bulletin papier (le bulletin numérique est l'enveloppe).
- ⚠ Croire que la receipt-freeness signifie l'absence de récépissé.
- ⚠ Penser que le chiffrement ElGamal seul assure le secret et l'intégrité sans preuves complémentaires.
- ⚠ Confondre l'élection politique avec les élections non politiques couvertes par le guide.
- ⚠ Oublier que la PDMA doit être nulle pour le vote.

Sigles et définitions

Élection non politique	Scrutin dont les listes électorales ne sont pas extraites du Répertoire électoral unique de l'INSEE
Bulletin	Donnée contenant le suffrage chiffré, correspondant à l'enveloppe du vote
Émargement	Mise à jour de la liste d'émargement attestant que l'électeur a voté
Récépissé	Document délivré à l'électeur ne contenant aucune information sur son bulletin
Preuve de vote	Donnée cryptographiquement liée au bulletin permettant de vérifier sa présence dans l'urne
Étanchéité	Stricte séparation entre l'identité de l'électeur et l'expression de son vote
Everlasting privacy	Garantie inconditionnelle du secret du scrutin, y compris face à un futur ordinateur quantique

Auto-test

1. Quelle est la valeur de la PDMA pour le vote ?
2. Que signifie la receipt-freeness ?
3. Combien de secrets d'authentification sont recommandés pour les niveaux 2 et 3 ?
4. Quel mécanisme de chiffrement est malléable ?
5. Comment appelle-t-on le vote sous contrainte ?

Réponses : **1.** Nulle · **2.** L'électeur ne peut pas prouver son suffrage à un tiers · **3.** Deux · **4.** ElGamal · **5.** La coercition

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.